

C1.2.3 - Cartographie des risques projet

Projet Spity : référentiel des risques techniques et fonctionnels, criticité, suivi des incidents et indicateurs de contrôle.

PROJET

Spity

COMMANDITAIRE

Collectif Altitude Grimpe

CERTIFICATION

Titre RNCP

LIVRABLE

Registre des risques

Objectif de la compétence

Cartographier les risques techniques et fonctionnels associés au projet, mettre en place un référentiel d'évaluation et de suivi des incidents, puis définir des indicateurs de contrôle afin de limiter leurs impacts sur la performance du développement.

Livrable attendu

Une cartographie priorisée des risques techniques et fonctionnels liés au MVP Spity.

Critères couverts

Perte de données, interruption du système, facteurs de dégradation, sécurité, criticité, référentiel et indicateurs.

Périmètre

Application web Next.js, API, base MariaDB, contenus communautaires, profils, lieux, topos, événements et données personnelles.

Finalité

Anticiper les incidents probables, réduire leur impact et définir une surveillance réaliste pour le contexte RNCP.

Référentiel d'évaluation des risques

Probabilité

Note de 1 à 4 : rare, possible, probable ou très probable selon la maturité technique, les dépendances et l'exposition utilisateur.

Impact

Note de 1 à 4 : mineur, significatif, majeur ou critique selon les effets sur données, sécurité, disponibilité ou démonstration.

Criticité

Score = probabilité x impact. 1-4 faible, 5-8 moyen, 9-12 élevé, 13-16 critique.

Cartographie des risques techniques

ID	Risque	Cause probable	Impact projet	Criticité	Mesure de maîtrise
RT-01	Perte de données	Migrations mal contrôlées, absence de sauvegarde ou erreur humaine.	Perte de profils, posts, événements, topos ou données de test.	16 Critique	Sauvegardes, migrations versionnées, seed contrôlé, jamais modifier les migrations existantes.
RT-02	Indisponibilité MariaDB	Conteneur arrêté, volume corrompu, configuration incorrecte.	Application inutilisable, routes API en erreur, démo bloquée.	12 Élevé	Procédure de relance Docker, healthcheck, sauvegarde du volume, script de vérification.
RT-03	Régression API	Modification non testée des routes auth, profil ou futures routes métier.	Parcours utilisateur cassé, impossibilité de créer ou consulter des données.	12 Élevé	Tests ciblés, validation Zod input/output, revue manuelle des endpoints critiques.
RT-04	Dégradation performance	Feed non paginé, images lourdes, requêtes sans index, carte trop chargée.	Temps de chargement élevé, mauvaise expérience mobile, abandon utilisateur.	9 Élevé	Pagination, compression médias, index DB, lazy loading, mesure temps de réponse.
RT-05	Dépendance service externe	Cartographie, stockage médias ou email indisponible ou limité par quota.	Fonctionnalités partielles, coûts imprévus, perte de confort en démo.	8 Moyen	Abstraction fournisseur, mode dégradé, quotas suivis, mocks pour démonstration.
RT-06	Erreur de configuration	Variables d'environnement absentes, secrets invalides, ports incohérents.	Application impossible à lancer ou comportement différent entre environnements.	9 Élevé	Validation Zod de l'environnement, '.env.example', documentation et contrôle avant démo.

Cartographie des risques fonctionnels

ID	Risque	Cause probable	Impact projet	Criticité	Mesure de maîtrise
RF-01	Adoption insuffisante	Pas assez de grimpeurs, clubs ou salles dans la zone pilote.	Feed vide, matching pauvre, valeur perçue faible.	12 Élevé	Onboarding d'acteurs pilotes, données de démonstration, ciblage Lyon-Grenoble.
RF-02	Matching peu pertinent	Données profil incomplètes, niveaux mal renseignés, critères trop simples.	Perte de confiance dans la promesse principale de mise en relation.	9 Élevé	Profil obligatoire, critères visibles, filtres par discipline, niveau, matériel et distance.
RF-03	Données topo erronées	Contribution non modérée, signalement ancien, cotation incorrecte.	Risque terrain, atteinte à la crédibilité et à la sécurité utilisateur.	16 Critique	Modération, historique, statut de confiance, signalements sécurité prioritaires.
RF-04	Événements clubs obsolètes	Clubs peu actifs ou absence de mise à jour après modification.	Inscriptions erronées, frustration utilisateur, perte de crédibilité club.	8 Moyen	Dates obligatoires, statut annulé/complet, rappel aux clubs, tri automatique.
RF-05	Contenus abusifs	Posts, commentaires ou médias inappropriés sans modération suffisante.	Dégradation communautaire, risques juridiques et image négative.	12 Élevé	Signalement, règles de contenu, modération, limitation uploads et suppression rapide.
RF-06	UX trop complexe	Périmètre large, navigation confuse, trop de filtres ou parcours incomplets.	Abandon utilisateur et difficulté de démonstration RNCP.	9 Élevé	Parcours prioritaires, interface mobile-first, tests manuels, composants UI cohérents.

Risques sécurité et conformité

ID	Risque	Cause probable	Impact projet	Criticité	Mesure de maîtrise
RS-01	Compte compromis	Mot de passe faible, absence de limitation, token mal protégé.	Accès non autorisé aux profils et actions utilisateur.	16 Critique	Hash bcrypt, secret fort, logout, rate limiting, cookies sécurisés.
RS-02	Exposition localisation	Affichage trop précis, absence de consentement ou paramètres privés.	Atteinte à la vie privée, non-conformité RGPD.	16 Critique	Minimisation, consentement, précision réduite, contrôle de visibilité.
RS-03	Injection / input invalide	Données API non validées, requête manuelle, faille formulaire.	Corruption de données, erreur serveur ou faille applicative.	12 Élevé	Zod, Drizzle ORM, validations serveur, erreurs normalisées.
RS-04	Fuite de secrets	Variable sensible committée, clé exposée côté client, configuration faible.	Compromission base, email, stockage média ou sessions.	16 Critique	Ne jamais committer <code>.env*</code> , audit secrets, variables serveur, rotation des clés.
RS-05	Upload dangereux	Type MIME non contrôlé, fichier trop lourd, média inapproprié.	Risque sécurité, coût de stockage, contenu abusif.	12 Élevé	Limites taille/type, stockage externe, scan ou modération, droits stricts.

Référentiel de suivi des incidents

Champs de suivi

- ID incident, date, auteur du signalement.
- Type : technique, fonctionnel, sécurité, donnée, performance.
- Sévérité : S1 critique, S2 majeure, S3 moyenne, S4 mineure.
- Statut : ouvert, qualifié, en cours, corrigé, vérifié, clos.
- Responsable, délai cible, cause racine et action corrective.

Règles de priorisation

- S1 : données, sécurité, auth ou démo bloquée, traitement immédiat.
- S2 : fonctionnalité majeure indisponible, correction sous 48 h.
- S3 : anomalie contournable, planification dans le sprint courant.
- S4 : amélioration ou gêne mineure, traitement selon capacité.

Indicateurs de contrôle

Indicateur	Objectif de contrôle	Seuil d'alerte	Fréquence
Taux d'erreurs API	Surveiller la stabilité des routes auth, profil, lieux et posts.	Plus de 2 % d'erreurs sur une période de test.	À chaque recette
Temps de réponse API	Détecter la dégradation des performances serveur.	Plus de 500 ms sur les endpoints critiques en local/démo.	Hebdomadaire
Disponibilité base	Contrôler la disponibilité MariaDB et la continuité de service.	Conteneur arrêté ou connexion DB impossible.	Avant chaque démo
Sauvegardes valides	Limiter l'impact d'une perte de données.	Aucune sauvegarde récente ou restauration non testée.	À chaque jalon
Échecs de connexion	Identifier brute force, problème UX ou compte compromis.	Hausse inhabituelle par compte ou IP.	Hebdomadaire
Dette bugs critiques	Mesurer les incidents bloquants non traités.	Un incident S1 ou plus de trois incidents S2 ouverts.	Hebdomadaire
Complétude profils	Contrôler la pertinence du matching.	Moins de 80 % des profils pilotes avec niveau, discipline et localisation.	Recette MVP
Délai de modération	Limiter l'impact des contenus abusifs et signalements sécurité.	Signalement critique non traité sous 24 h.	À chaque signalement

Mesures prioritaires de réduction des risques

Données et disponibilité Sauvegardes, migrations versionnées, contrôles de connexion DB, index sur les tables de recherche et scénario de restauration.	Sécurité Validation Zod, rate limiting, protection des secrets, permissions serveur, limitation des uploads et minimisation des localisations.	Fonctionnel Parcours MVP verrouillé, données de démo, onboarding club pilote, modération minimale et tests manuels des parcours critiques.
---	--	--

Synthèse

Les risques majeurs du projet Spity concernent la perte de données, l'interruption de la base, la sécurité des comptes, la protection des localisations, la fiabilité des topos et la capacité du MVP à générer suffisamment de valeur avec une communauté pilote limitée.

Le référentiel proposé permet de prioriser ces risques par criticité, de suivre les incidents et de contrôler leur impact par des indicateurs simples. Les actions les plus importantes sont la sécurisation des données, la validation systématique, la modération, les sauvegardes et le verrouillage du périmètre démontrable.

Document produit pour le dossier RNCP - Bloc C1 - Projet Spity.